Lab 5: Static Code Analysis

Courier & Parcel Tracking System (parcel_tracker.py)

Name	Sateesh
SRN	PES1UG24AM397
Course / Section	G
Tools used	Pylint, Bandit, Flake8
Date	16 October 2026

1. Objective

To improve the quality, security and style of an assigned Python script by running three static analysis tools, documenting the issues they report, fixing them in order of severity, and verifying the fixes by re-running the tools.

2. Environment Setup

```
python3 -m venv venv
source venv/bin/activate        # Windows: venv\Scripts\activate
pip install pylint bandit flake8
```

3. Program Description and Baseline Run

parcel_tracker.py books parcels with tracking ids, moves them through the stages Booked → Picked Up → In Transit → Out for Delivery → Delivered, tracks a parcel, checks if it is still with the courier, generates a delivery OTP and computes shipping cost. Output of the original program (python parcel_tracker.py):

```
Bengaluru Books -> Ravi Kumar: In Transit
  with courier: True
  cost: 95.0
Gadget Hub -> Sneha Rao: Picked Up
  with courier: True
  cost: 50
Spice Store -> Imran Khan: Delivered
  with courier: False
  cost: 140
Unknown tracking id TRK00000
Delivery OTP for TRK10003 is 4167
Parcels booked today: 3
```

The OTP is random, so it differs on every run; everything else must stay identical after the fixes.

4. Static Analysis Results – Before

Tool	Before	After
Pylint	4.91 / 10 (27 messages)	10.00 / 10
Bandit	4 issues: 1 High, 1 Medium, 2 Low	0 issues
Flake8	4 issues (E225, E261, E231, E305)	0 issues

4.1 Pylint report (before)

```
************* Module parcel_tracker
parcel_tracker.py:1:0: C0114: Missing module docstring (missing-module-docstring)
parcel_tracker.py:11:0: C0116: Missing function or method docstring (missing-function-docstring)
```

```
parcel_tracker.py:11:0: C0103: Function name "bookParcel" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:11:33: C0103: Argument name "weightKg" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:11:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
parcel_tracker.py:12:4: C0103: Variable name "trackingId" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:20:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker.py:20:0: C0103: Function name "advanceStatus" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:20:18: C0103: Argument name "trackingId" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:27:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker.py:27:0: C0103: Function name "shippingCost" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:27:17: C0103: Argument name "weightKg" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:34:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker.py:34:0: C0103: Function name "trackParcel" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:34:16: C0103: Argument name "trackingId" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:37:11: W0718: Catching too general exception Exception (broad-exception-caught)
parcel_tracker.py:43:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker.py:43:0: C0103: Function name "isWithCourier" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:43:18: C0103: Argument name "trackingId" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:45:11: R1714: Consider merging these comparisons with 'in' by using 'status in
('Picked Up', 'In Transit')'. Use a set instead if elements are hashable. (consider-using-in)
parcel_tracker.py:48:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker.py:48:0: C0103: Function name "labelPath" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:53:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker.py:53:0: C0103: Function name "pingHub" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:53:12: C0103: Argument name "hubAddress" doesn't conform to snake_case naming style
(invalid-name)
parcel_tracker.py:58:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker.py:67:8: C0103: Variable name "trackingId" doesn't conform to snake_case naming style
(invalid-name)


-----------------------------------
Your code has been rated at 4.91/10
```

4.2 Bandit report (before)

```
Run started:2026-10-16 03:39:00.364680+00:00


Test results:
>> Issue: [B404:blacklist] Consider possible security implications associated with the subprocess
module.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-import-
subprocess
   Location: ./parcel_tracker.py:2:0
1       import random
2       import subprocess
3import tempfile


--------------------------------------------------
>> Issue: [B306:blacklist] Use of insecure and deprecated function (mktemp).
   Severity: Medium   Confidence: High
   CWE: CWE-377 (https://cwe.mitre.org/data/definitions/377.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b306-mktemp-q
   Location: ./parcel_tracker.py:50:11
49          # Helper kept for the lab: not called by the demo
50    return tempfile.mktemp(suffix=".txt")
51


--------------------------------------------------
```

```
>> Issue: [B602:subprocess_popen_with_shell_equals_true] subprocess call with shell=True identified,
security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b602_subprocess_popen_with_shell_equals_true.html
   Location: ./parcel_tracker.py:55:11
54          # Helper kept for the lab: not called by the demo
55    return subprocess.check_output("ping -c 1 " + hubAddress, shell=True)
56


--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for
security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: ./parcel_tracker.py:72:19
71    print(trackParcel("TRK00000")) # unknown id
72    delivery_otp = random.randint(1000, 9999)
73    print("Delivery OTP for", third, "is", delivery_otp)


--------------------------------------------------


Code scanned:
        Total lines of code: 56
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 1
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 4
Files skipped (0):
```

4.3 Flake8 report (before)

```
parcel_tracker.py:28:9: E225 missing whitespace around operator
parcel_tracker.py:71:35: E261 at least two spaces before inline comment
parcel_tracker.py:74:34: E231 missing whitespace after ','
parcel_tracker.py:75:1: E305 expected 2 blank lines after class or function definition, found 0
```

5. Issue Table

Ordered with high and medium severity first. 13 issues documented; all were fixed (the lab requires at least 4).

#	Issue	Type	Line(s)	Description	Fix approach
1	subprocess with shell=True (B602)	Security – High	55	Command string built from user input and run in a shell: `8.8.8.8; rm -rf /` would run extra commands (CWE-78).	Validate with ipaddress.ip_address(), pass an argument list, shell=False, add timeout.
2	Insecure temp file – mktemp (B306)	Security – Medium	50	mktemp only returns a name; another process can create it first (race condition, CWE-377).	Use tempfile.NamedTemporaryFile(delete=False).
3	Mutable default	Bug	11	history=[] is created once and shared across all calls.	Default to None; create the list inside the function.

#	Issue	Type	Line(s)	Description	Fix approach
	argument (W0102)				
4	Broad exception (W0718)	Bug / Quality	37	except Exception hides unrelated errors.	Catch only KeyError.
5	Weak random for OTP (B311)	Security – Low	72	random.randint is predictable (CWE-330).	secrets.randbelow().
6	subprocess import (B404)	Security – Low	2	Informational warning for importing subprocess.	Import needed; usage made safe; annotated # nosec B404.
7	Not snake_case (C0103)	Style	11–67	bookParcel, weightKg, trackingId, pingHub ...	Rename to PEP 8 snake_case.
8	Missing docstrings (C0114, C0116)	Style	1, 11–58	Module and all functions undocumented.	Add docstrings.
9	Merge comparisons (R1714)	Refactor	45	status == 'A' or status == 'B'	status in ('Picked Up', 'In Transit')
10	E225 missing whitespace	Style (Flake8)	28	cost=50	cost = 50
11	E261 comment spacing	Style (Flake8)	71	One space before inline #.	Two spaces before #.
12	E231 missing space after comma	Style (Flake8)	74	"today:",len(...)	Add a space after the comma.
13	E305 blank lines / import side effect	Style (Flake8)	75	main() directly after function; runs on import.	Two blank lines + if __name__ == '__main__' guard.

6. Fixes Applied (key before / after)

6.1 Command injection – shell=True (Bandit B602, High)

Before:

```
def pingHub(hubAddress):
    return subprocess.check_output("ping -c 1 " + hubAddress, shell=True)
```

After:

```
def ping_hub(hub_address):
    ipaddress.ip_address(hub_address)  # ValueError if not a valid IP
    return subprocess.check_output(  # nosec B603 B607
        ["ping", "-c", "1", hub_address], timeout=10)
```

Tested: ping_hub('8.8.8.8; rm -rf /') now raises ValueError instead of running a shell command.

6.2 Insecure temp file – mktemp (Bandit B306, Medium)

```
# Before
return tempfile.mktemp(suffix=".txt")


# After
with tempfile.NamedTemporaryFile(suffix=".txt", delete=False) as tmp:
    return tmp.name
```

6.3 Mutable default argument (Pylint W0102)

```
# Before
def bookParcel(sender, receiver, weightKg, history=[]):


# After
def book_parcel(sender, receiver, weight_kg, history=None):
    if history is None:
        history = []
```

6.4 Broad exception (Pylint W0718)

```
# Before
except Exception:
# After
except KeyError:
```

6.5 Weak random number for OTP (Bandit B311)

```
# Before
delivery_otp = random.randint(1000, 9999)
# After
delivery_otp = 1000 + secrets.randbelow(9000)
```

6.6 Style fixes

- Flake8: cost = 50; two spaces before the inline comment; space after the comma; two blank lines before main(); if __name__ == "__main__": guard.
- Pylint: all functions/arguments/variables renamed to snake_case; module and function docstrings added; status in ("Picked Up", "In Transit").

7. Static Analysis Results – After

Tool	Before	After
Pylint	4.91 / 10 (27 messages)	10.00 / 10
Bandit	4 issues: 1 High, 1 Medium, 2 Low	0 issues
Flake8	4 issues (E225, E261, E231, E305)	0 issues

7.1 Pylint report (after)

```


-------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 4.91/10, +5.09)
```

7.2 Bandit report (after)

```
Run started:2026-10-16 03:39:37.232624+00:00

Test results:
No issues identified.

Code scanned:
        Total lines of code: 75
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 3

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
```

```
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

7.3 Flake8 report (after)

```
(empty – no issues reported)
```

7.4 Program output after the fixes

```
Bengaluru Books -> Ravi Kumar: In Transit
  with courier: True
  cost: 95.0
Gadget Hub -> Sneha Rao: Picked Up
  with courier: True
  cost: 50
Spice Store -> Imran Khan: Delivered
  with courier: False
  cost: 140
Unknown tracking id TRK00000
Delivery OTP for TRK10003 is 8249
Parcels booked today: 3
```

Output is identical to the baseline except for the random OTP, so behaviour is preserved.

8. Git Commits

One commit per tool, as required by the handout:

Commit	What changed	Message to use
1 – Bandit	Safe ping (no shell + IP validation + timeout), NamedTemporaryFile, secrets for OTP, nosec on subprocess import	fix: resolve Bandit security issues (shell=True, mktemp, weak random)
2 – Flake8	Spacing around =, two spaces before #, space after comma, blank lines before main()	style: fix Flake8 formatting issues
3 – Pylint	snake_case renames, docstrings, history=None, except KeyError, 'in' check, __main__ guard	refactor: fix Pylint issues (naming, docstrings, mutable default, except)

Repository link: _____ (paste commit log / screenshot here)

9. Final Cleaned Code (parcel_tracker.py)

```
"""Parcel tracker for a courier service.

Books parcels, moves them through the delivery stages, tracks a parcel by id,
checks whether it is with the courier and works out the shipping cost.
"""
import ipaddress
import secrets
import subprocess  # nosec B404
import tempfile
from datetime import date

STATUS_FLOW = ["Booked", "Picked Up", "In Transit",
               "Out for Delivery", "Delivered"]
parcels = {}



def book_parcel(sender, receiver, weight_kg, history=None):
    """Book a parcel and return its new tracking id."""
    if history is None:
        history = []
```

```
    tracking_id = "TRK" + str(10001 + len(parcels))
    parcels[tracking_id] = {"sender": sender, "receiver": receiver,
                            "weight": weight_kg, "status": 0,
                            "booked": str(date.today())}
    history.append(tracking_id)
    return tracking_id



def advance_status(tracking_id):
    """Move a parcel to its next delivery stage and return the new stage."""
    parcel = parcels[tracking_id]
    if parcel["status"] < len(STATUS_FLOW) - 1:
        parcel["status"] += 1
    return STATUS_FLOW[parcel["status"]]



def shipping_cost(weight_kg):
    """Return the shipping cost: 50 base plus 30 per kg above the first."""
    cost = 50
    if weight_kg > 1:
        cost += (weight_kg - 1) * 30
    return round(cost, 2)



def track_parcel(tracking_id):
    """Return a readable route and status line for a parcel."""
    try:
        parcel = parcels[tracking_id]
    except KeyError:
        return "Unknown tracking id " + tracking_id
    route = parcel["sender"] + " -> " + parcel["receiver"]
    return route + ": " + STATUS_FLOW[parcel["status"]]



def is_with_courier(tracking_id):
    """Return True while the parcel is picked up or in transit."""
    status = STATUS_FLOW[parcels[tracking_id]["status"]]
    return status in ("Picked Up", "In Transit")



def label_path():
    """Create a unique temporary label file safely and return its path."""
    with tempfile.NamedTemporaryFile(suffix=".txt", delete=False) as tmp:
        return tmp.name



def ping_hub(hub_address):
    """Ping a hub by IP address (validated, no shell) and return output."""
    ipaddress.ip_address(hub_address)  # ValueError if not a valid IP
    return subprocess.check_output(  # nosec B603 B607
        ["ping", "-c", "1", hub_address], timeout=10)



def main():
    """Run a short demonstration of the parcel tracker."""
    first = book_parcel("Bengaluru Books", "Ravi Kumar", 2.5)
    second = book_parcel("Gadget Hub", "Sneha Rao", 0.8)
    third = book_parcel("Spice Store", "Imran Khan", 4)
    advance_status(first)
    advance_status(first)
    advance_status(second)
    for _ in range(6):
        advance_status(third)
    for tracking_id in (first, second, third):
        print(track_parcel(tracking_id))
        print("  with courier:", is_with_courier(tracking_id))
        print("  cost:", shipping_cost(parcels[tracking_id]["weight"]))
    print(track_parcel("TRK00000"))  # unknown id
    delivery_otp = 1000 + secrets.randbelow(9000)
    print("Delivery OTP for", third, "is", delivery_otp)
```

```
    print("Parcels booked today:", len(parcels))


if __name__ == "__main__":
    main()
```

10. Reflection

1. Which tool was most useful, and why?

Bandit found the most serious problems: shell=True (command injection) and mktemp (race condition) are real vulnerabilities that Pylint and Flake8 do not report. Pylint gave the biggest quality gain (4.91 → 10.00) by catching the mutable default argument, the broad except, naming and missing docstrings. Flake8 was the quickest to fix because it only reports formatting.

2. Any false positives or items you disagreed with?

B404 (importing subprocess) is informational only; the module is needed. I kept it and added # nosec B404, plus # nosec B603 B607 on the ping call because the address is validated and shell=False is used. A nosec must always be justified, otherwise it just hides a real problem.

3. How does static analysis fit into development?

It runs without executing the code, so it can run in the editor, as a pre-commit hook or in CI on every push. Problems are caught while cheap to fix, reviewers focus on design instead of style, and security mistakes are caught before release. It does not replace testing: I ran the program before and after to confirm identical behaviour.

4. What did you learn?

Code that 'works' can still be unsafe or fragile: a shared mutable default, a predictable OTP, an unsafe temp file and an injectable shell command all ran fine in the demo. Fixing by severity and committing one tool at a time made each change easy to verify by re-running that tool.

11. Conclusion

All 13 identified issues were fixed: Bandit went from 4 issues (1 High) to 0, Flake8 from 4 to 0, and Pylint from 4.91 to 10.00/10, with the program’s behaviour unchanged.